PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité de l'IIoT et de la GTB

03-1000 ANSSI - Internet des objets industriels et gestion technique du bâtiment — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'IIoT augmente la surface d'attaque face aux cybercriminels et aux groupes soutenus par des États.
2. Le système industriel doit pouvoir rejeter une consigne intelligente en passant en mode local via le mode island.
3. La sécurisation de la GTB repose sur le cloisonnement du réseau d'administration et l'usage de VPN IPsec pour l'accès distant.

L'Internet industriel des objets (IIoT)

Notion	À retenir
Nouveaux usages	Captation et valorisation de données via **traitements automatisés de masse**. Usages : **maintenance prédictive**, **apprentissage profond**, simulation, accès **populations externes**, revente de données et **consignes intelligentes**.
Menaces	Augmentation de la **surface d'attaque**. Cibles : **cybercriminels** (attaques lucratives de masse) et **groupes soutenus par des États** (espionnage ou déstabilisation).

Risques et scénarios IIoT

Notion	À retenir
Familles de scénarios	Atteintes à la **disponibilité**, l'**intégrité** (système industriel et données) et la **confidentialité** (données de collecte), ainsi qu'aux **fonctions de la chaîne de traitement**.
Consigne intelligente	Risques sur le **stockage hors système**, les **algorithmes de calcul** et le **transport de la consigne** vers le système industriel.

Exemples de menaces et impacts

- **Maintenance prédictive** : un arrêt inacceptable peut survenir si le procédé repose entièrement sur l'**IIoT**.
- **Centrifugeuse** : un attaquant contrôlant l'IIoT neutralise les alertes et augmente de façon **infime** la vitesse de rotation ; usure, casse avant la maintenance, arrêt de production.
- **Ver Stuxnet** : conçu en **2010** pour s'attaquer aux centrifugeuses iraniennes d'enrichissement d'uranium jusqu'à leur **destruction physique**.

Confiance et architecture

Notion	À retenir
Mesures fonctionnelles	Niveau de confiance contextualisé (**score**) : **très élevé** = intégration en temps réel ; **élevé** = intégration puis vérification a posteriori ; **médiocre** = validation humaine préalable. Rejet de consigne possible via **mode local** (**mode island** IEC 62443).
Architecture sécurisée	Repose sur **3 éléments** : passerelle **usine vers entreprise**, passerelle **entreprise vers usine** et **infrastructure de transport** sécurisée.
Périmètre élargi	Périmètre s'étend à la **zone entreprise** (même externalisée). Analyse de risque : **sûreté des traitements** (fonctionnement/qualité) et **sécurité de l'infrastructure** (IT/OT).

Recommandations de sécurité GTB

Notion	À retenir
Définition/Périmètre	La **GTB** pilote à distance les éléments d'un bâtiment ; la **GTC** en est un sous-élément. Guide **ANSSI-PA-110** (2026) : **26 recommandations**, **N1** (court/moyen terme) et **N2** (moyen/long terme) ; prochaine version : BACnet/SC.
Administration/Cloisonnement	Poste d'ingénierie **dédié et sécurisé**. Réseau d'administration cloisonné. Accès distant : **VPN IPsec** (ou **VPN TLS** à défaut). Désactiver **Foreign Device** (BACnet).
Défense en profondeur	Ports muraux (public) cloisonnés et inutilisés désactivés. Durcir commutateurs, passerelles (ex: **RS485 vers TCP/IP**) et automates (micrologiciel, mot de passe, services inutiles, journalisation).
Communications	Privilégier les protocoles sécurisés. Wi-Fi à **chiffrement robuste** ; sans fil non sécurisé réservé aux composants **non sensibles**. Sécuriser **Modbus** et **BACnet**.

Mesures de protection physique et matérielle

- **Ports Ethernet muraux** : cloisonner dans les lieux accueillant du public et désactiver les ports inutilisés.
- **Commutateurs** : durcir les équipements et mettre en place des **private VLAN**.
- **Automates** : garantir la synchronisation horaire, vérifier l'intégrité du micrologiciel/configuration, protéger par mot de passe, activer le contrôle d'accès IP et la journalisation.
- **Ports USB** : bloquer les ports inutilisés.
- **BIOS/UEFI** : sécuriser l'accès.
- **Médias amovibles** : faire passer par un **sas** ou une **station blanche**.

Pièges et confusions

⚠ Confondre la consigne intelligente avec une donnée IIoT classique.
⚠ Croire que le système industriel doit exécuter aveuglément la consigne calculée hors de l'usine.
⚠ Oublier qu'une modification infime d'une consigne peut détruire un équipement sans alerte.
⚠ Penser que la GTC est l'élément global alors qu'elle est un sous-élément de la GTB.
⚠ Confondre la station blanche avec un simple poste de travail.

Sigles et définitions

IIoT — Infrastructure industrielle d'entités et de systèmes interconnectés traitant les informations du monde physique et virtuel.

Consigne intelligente — Consigne calculée hors de l'usine par des algorithmes puis renvoyée au procédé.

Mode island — Capacité d'un système industriel à couper toute communication et à fonctionner en mode local.

GTB — Gestion technique du bâtiment permettant de contrôler à distance plusieurs éléments d'un bâtiment.

Station blanche — Poste de décontamination par lequel passent les médias amovibles avant introduction dans un système.

Modèle de Purdue — Grille de lecture représentant l'usine comme un empilement de zones, des capteurs jusqu'à l'ERP.

Auto-test

1. Quel est le cas d'usage IIoT le plus sensible ?
2. Par quel moyen l'accès distant à la GTB doit-il passer de préférence ?
3. Que signifie le mode island prévu par l'IEC 62443 ?
4. Quels sont les deux protocoles de communication couramment utilisés en GTB souvent dépourvus de sécurité native ?
5. À quoi sert le poste d'ingénierie ?

Réponses : **1.** La consigne intelligente calculée hors de l'usine. · **2.** Un VPN IPsec. · **3.** La capacité de fonctionner en mode local en coupant toute communication à sa frontière. · **4.** Modbus et BACnet. · **5.** À programmer et configurer les automates.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.